第二次社課：

Web Security 入門

Frank

復旦資研 - 115/10/07


拜託ATM
BATTLE
頂尖大學金頭腦爭霸戰
成功大學
TVBS歡樂台 HD
我們是做好駭客



法規名稱：中華民國刑法 EN

法規類別：行政 ＞ 法務部 ＞ 檢察目

※如已配合行政院組織改造，公告變更管轄或停止辦理業務之法規條文，請詳見沿革

第 359 條	無故取得、刪除或變更他人電腦或其相關設備之電磁紀錄，致生損害於公眾或他人者，處五年以下有期徒刑、拘役或科或併科六十萬元以下罰金。



法規名稱：個人資料保護法 EN

生效狀態：※本法規部分或全部條文尚未生效，最後生效日期：未定 連結舊法規內容

1.一百十二年五月三十一日增訂之第 1-1 條條文，施行日期，由行政院定之。

2.一百十四年十一月十一日修正第 1-1、12、18、21、22～26、41、47～49、52、53、55 條條文；增訂第 1-2、20-1、21-1～21-5、51-1、53-1 條條文及第三章之一章名、第一節節名、第二節節名；刪除第 27 條條文，施行日期，由行政院定之。

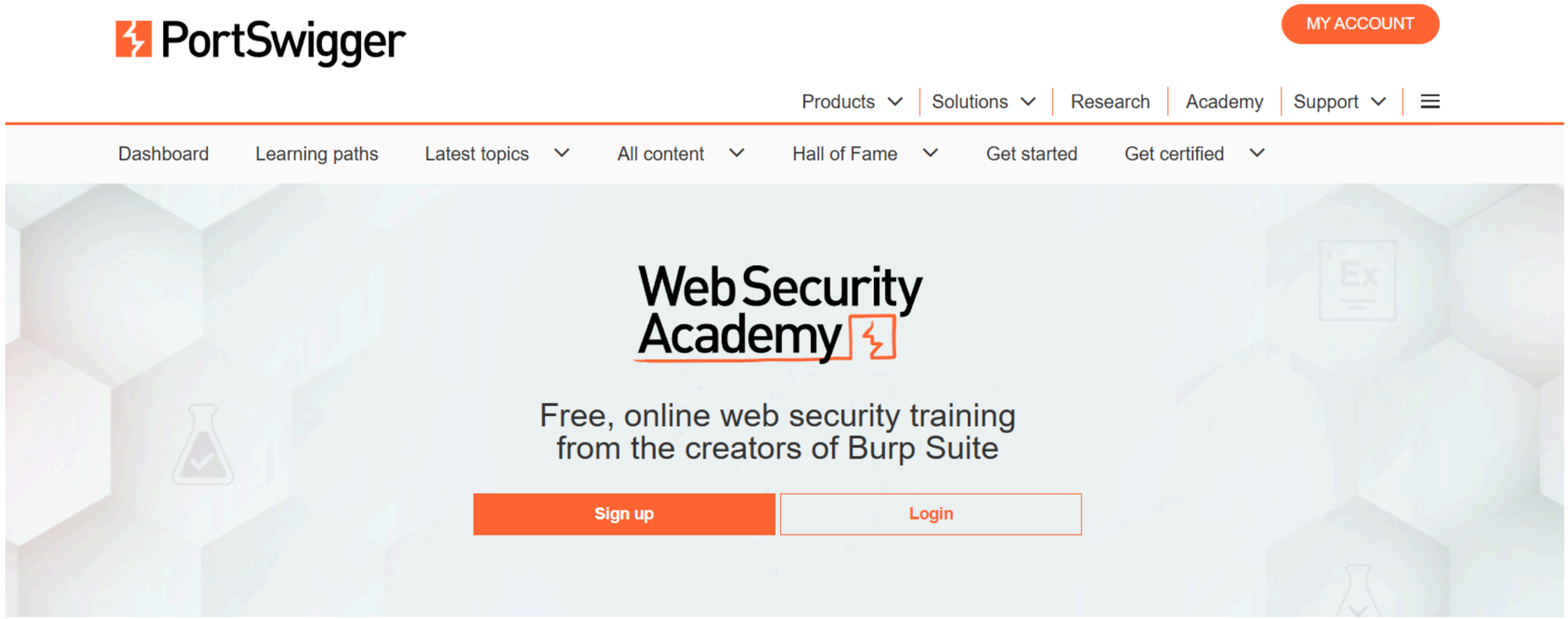
法規類別：行政 ＞ 個人資料保護委員會籌備處 ＞ 通用目

※如已配合行政院組織改造，公告變更管轄或停止辦理業務之法規條文，請詳見沿革

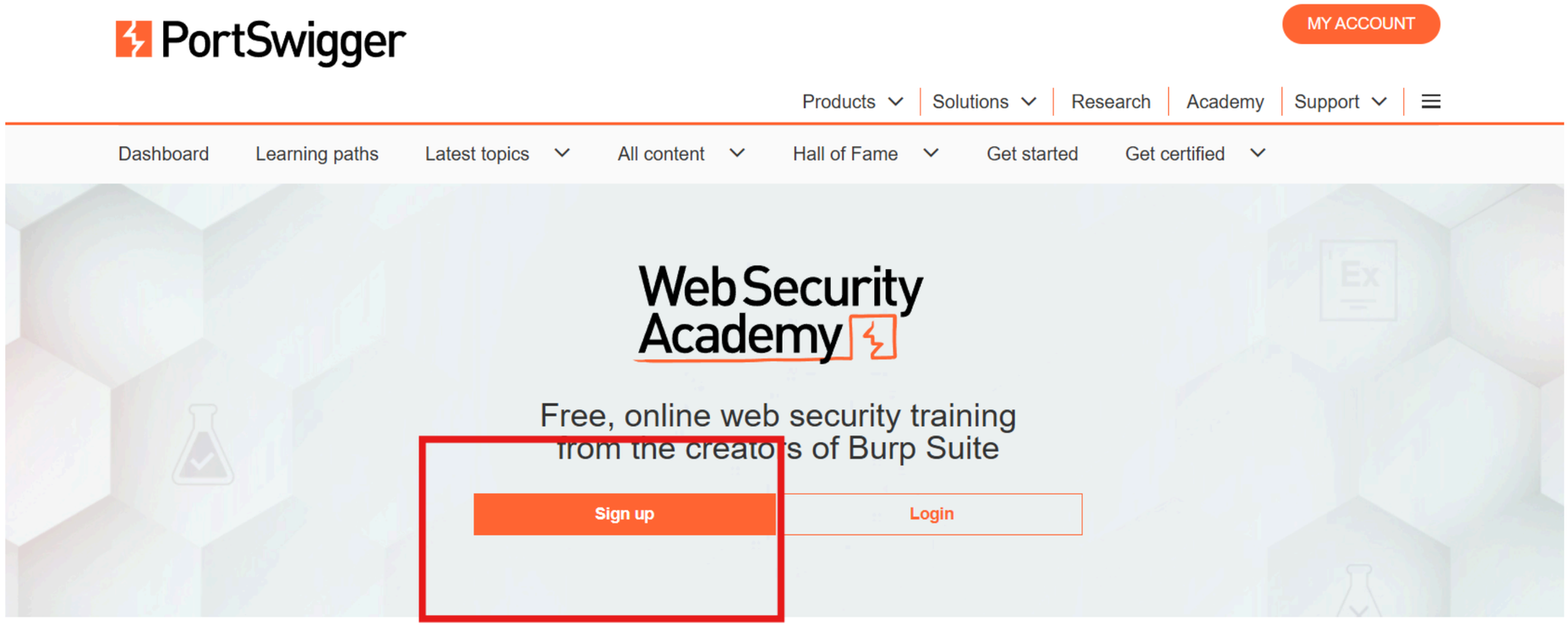
第 41 條　意圖為自己或第三人不法之利益或損害他人之利益，而違反第六條第一項、第十五條、第十六條、第十九條、第二十條第一項規定，或依第二十一條限制國際傳輸之命令或處分，足生損害於他人者，處五年以下有期徒刑，得併科新臺幣一百萬元以下罰金。

相關法條

開 Burp Suite

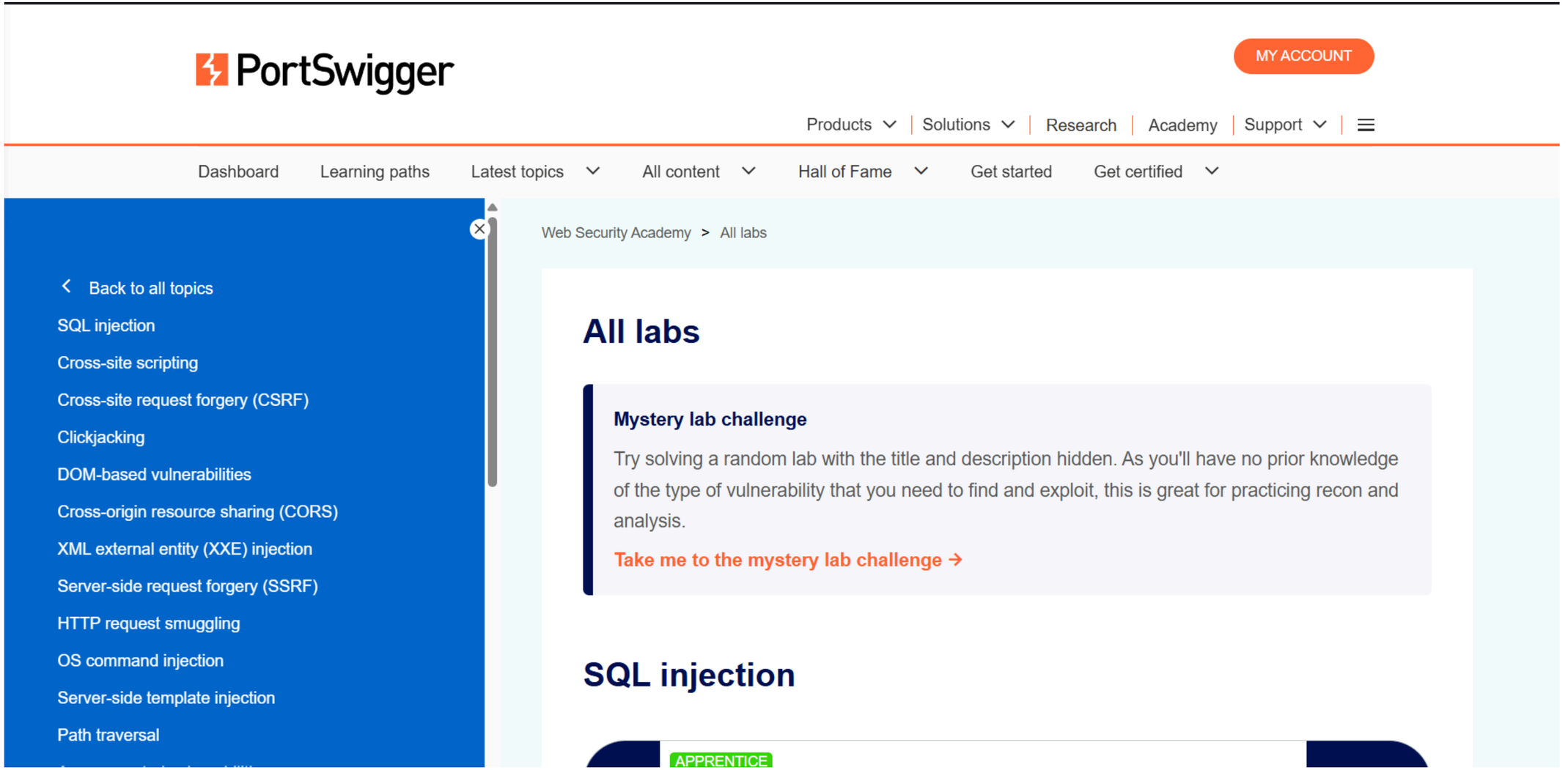


PortSwigger Academy


PortSwigger
MY ACCOUNT
Products
Solutions
Research
Academy
Support
Dashboard
Learning paths
Latest topics
All content
Hall of Fame
Get started
Get certified
Web Security Academy
Free, online web security training from the creators of Burp Suite
Sign up
Login
Boost your career
The Web Security Academy is a strong step toward a career in cybersecurity.
Flexible learning
Learn anywhere, anytime, with free interactive labs and progress-tracking.
Learn from experts
Produced by a world-class team - led by the author of The Web Application Hacker's Handbook.

註冊

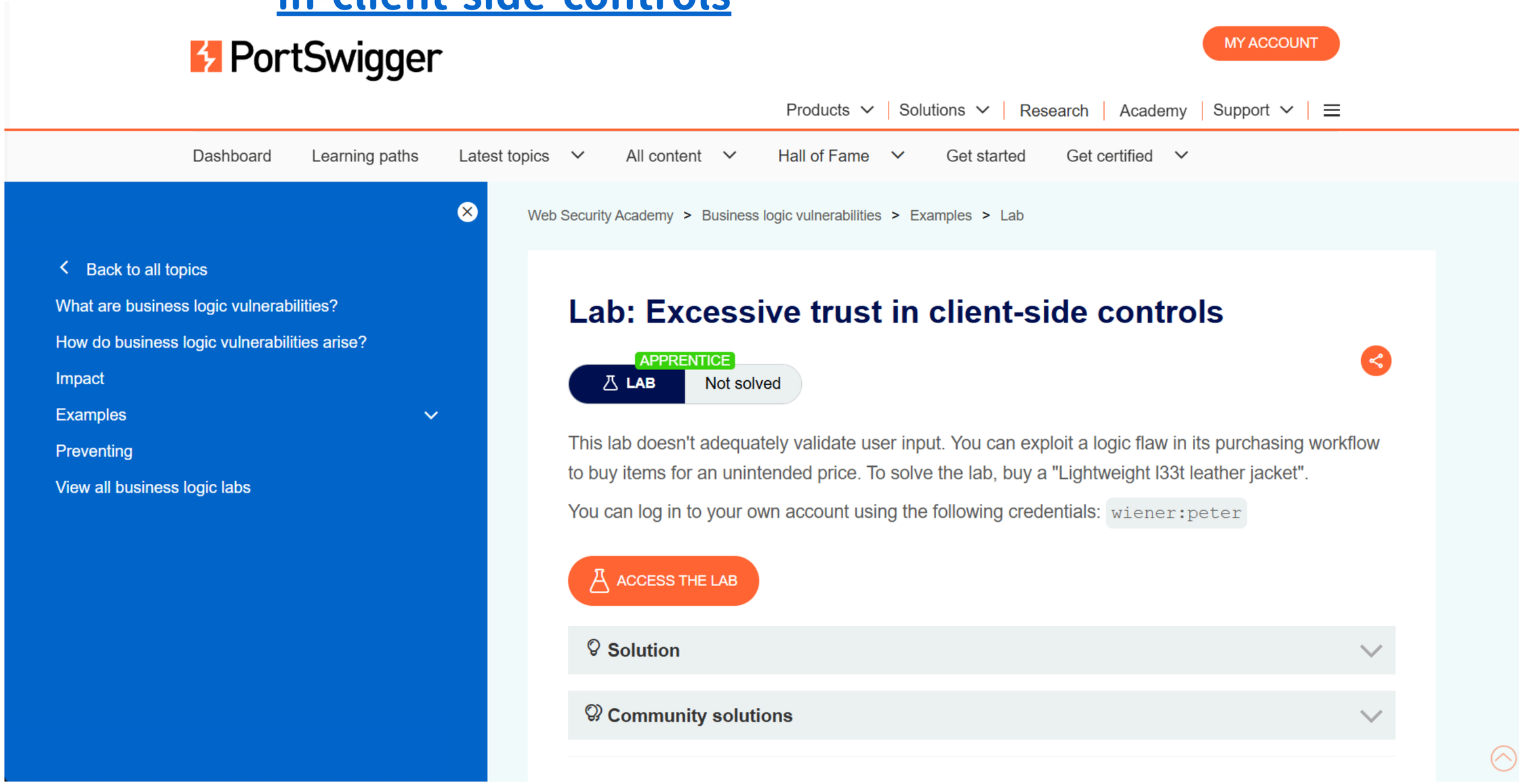
https://portswigger.net/web-security/all-labs

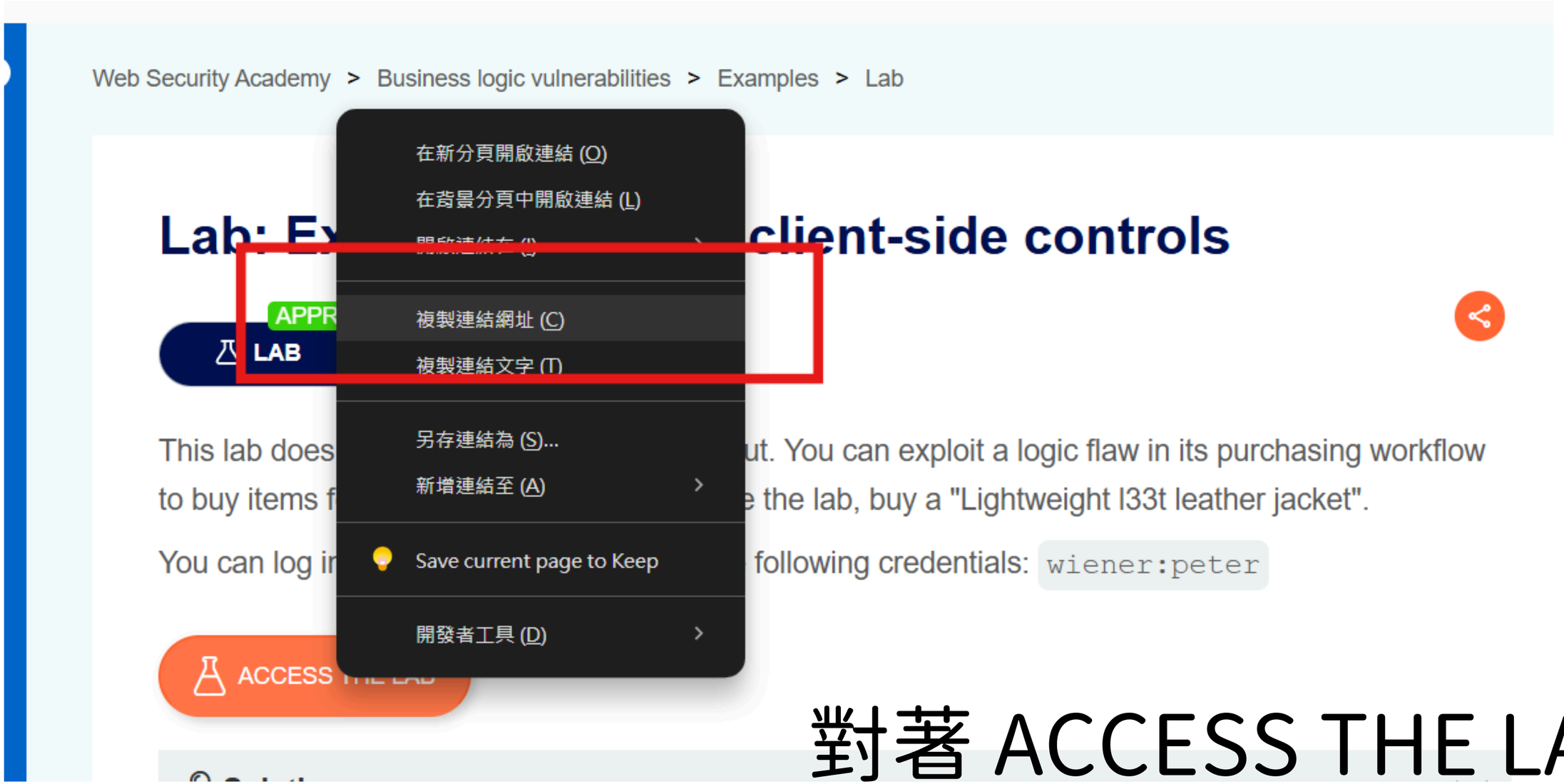


邏輯洞


後端
瀏覽器

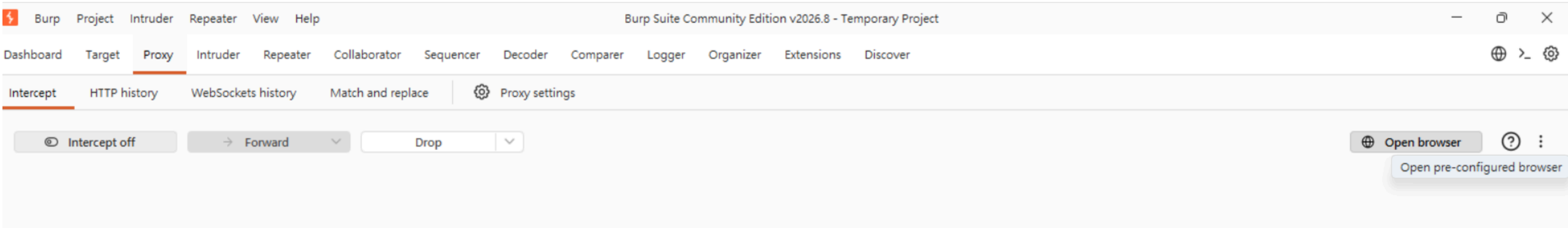
https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-excessive-trust-in-client-side-controls



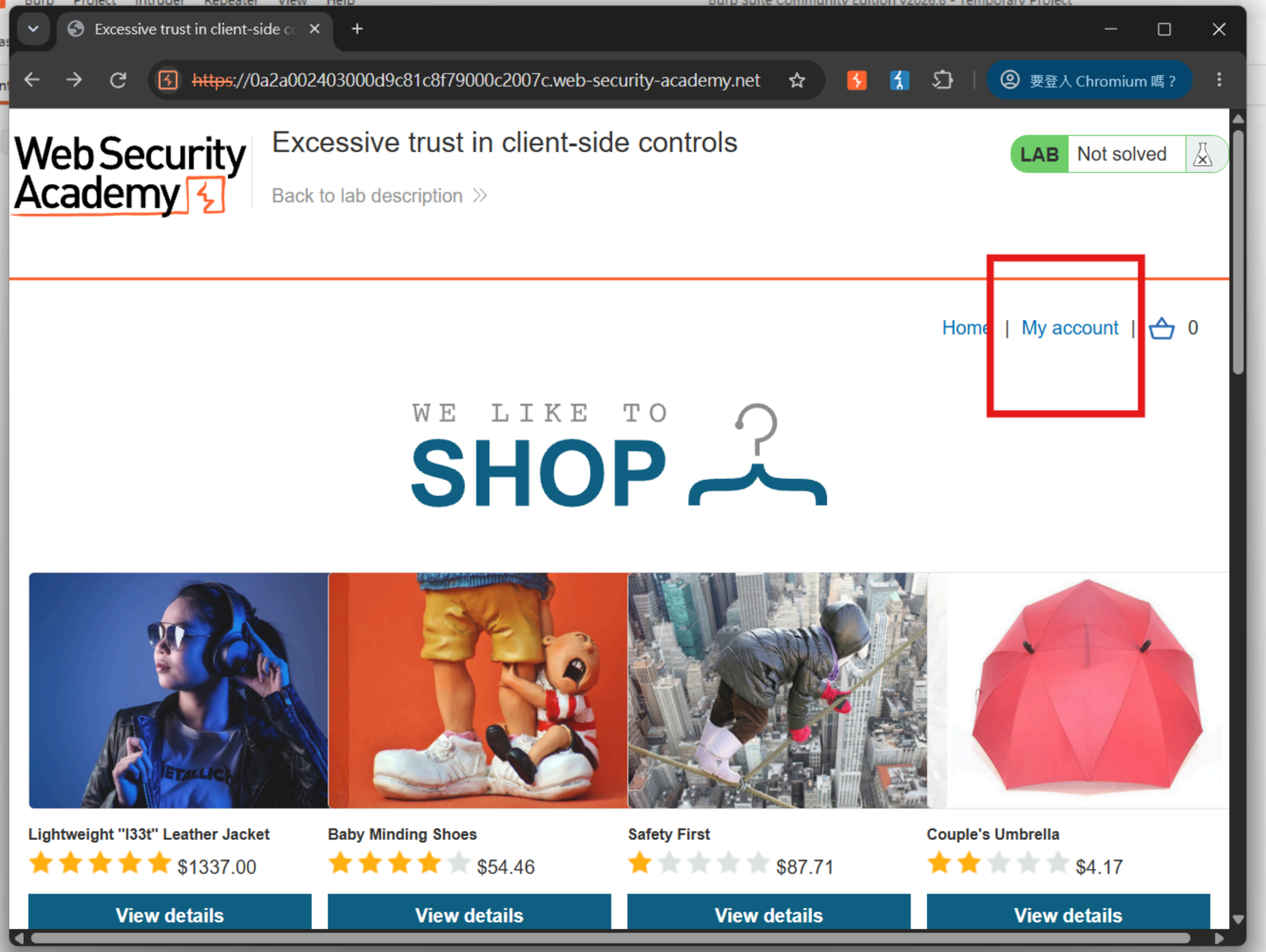


對著 ACCESS THE LAB

按右鍵，選複製連結網址



把複製好的連結貼在 Burp 裡面的瀏覽器



帳號密碼是

wiener/peter

Store credit:
$100.00

Home | My account | 0

WE LIKE TO
SHOP



Lightweight "33t" Leather Jacket
$1337.00



Baby Minding Shoes
$54.46



Safety First
$87.71



Couple's Umbrella
$4.17

可以看到題目要我們買外套，但餘額不夠



Description:

Do you often feel as though people aren't aware of just how "l33t" you are? Do you find yourself struggling to make others feel inferior with public displays of your advanced "l33t-ness"? If either of these things are at the top of your priority list, it's time to the welcome Lightweight "l33t" Leather Jacket into your life.

Handcrafted from leather and single strands of recycled bitcoin, so you can enjoy environmental smugness on top of your high-ranking leather-clad "l33t" levels, this jacket is far superior to anything currently available on the high street. Once you've explained to your friends and colleagues what "l33t" means, we guarantee you'll be at least 18% cooler when donning your "l33t" leather. Inspired by the term-coiners, the jacket comes with hand-stitched CISSP insignia so you can channel the original elite every time you rock your Lightweight "l33t" Leather Jacket.

Make your apparel as formidable as your intellect, and dazzle noobs the world over, with the Lightweight "l33t" Leather Jacket.*

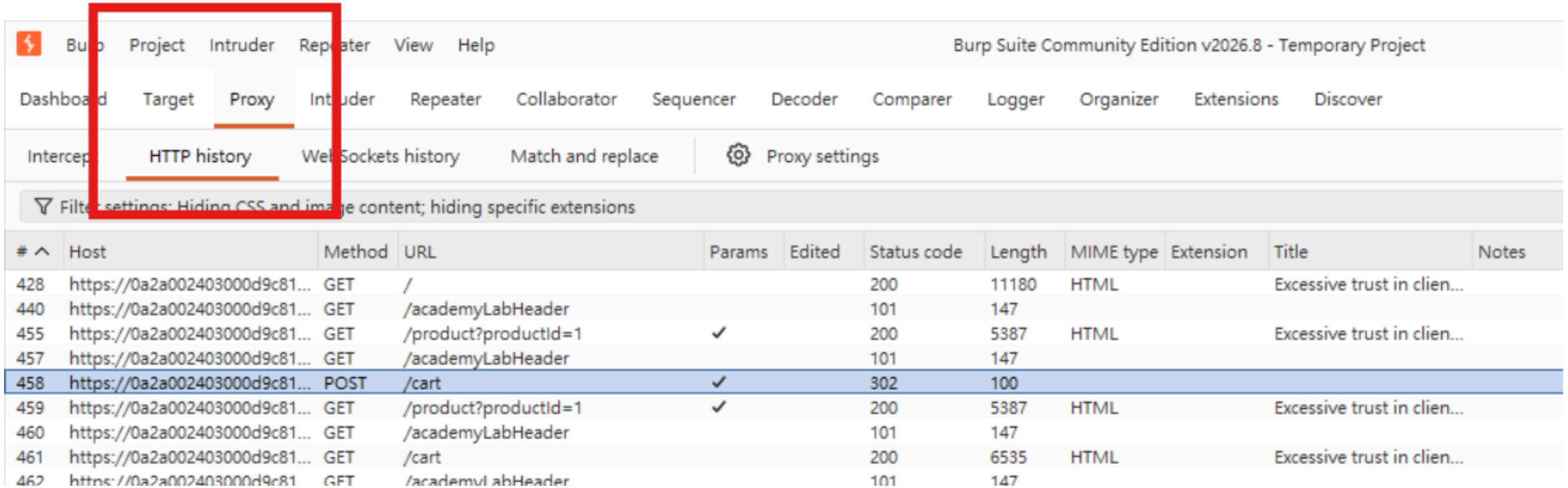
*Every purchase comes with a free leaflet, detailing how best to explain the superiority of being "l33t" to noobs.

1

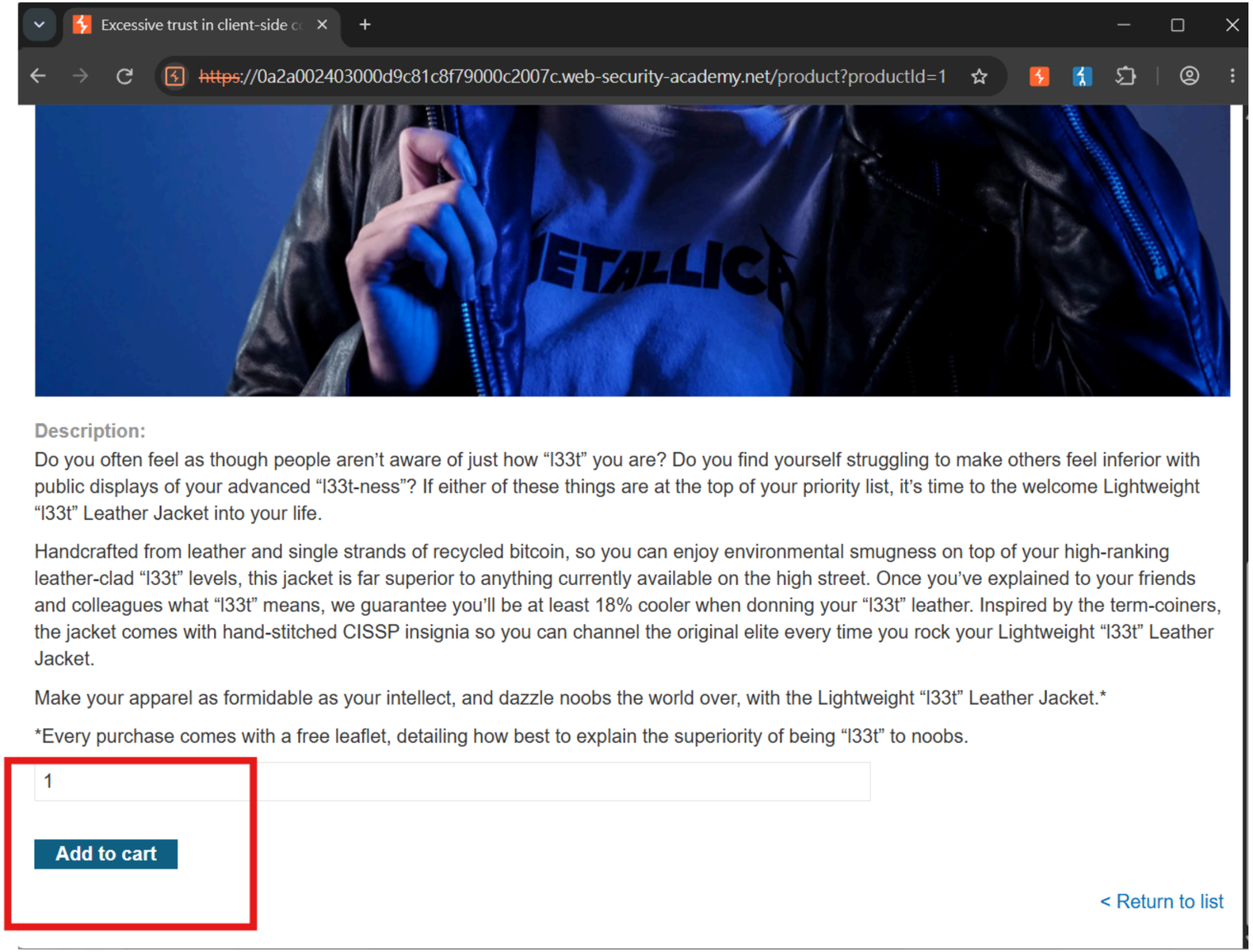
Add to cart

先點進商品頁面

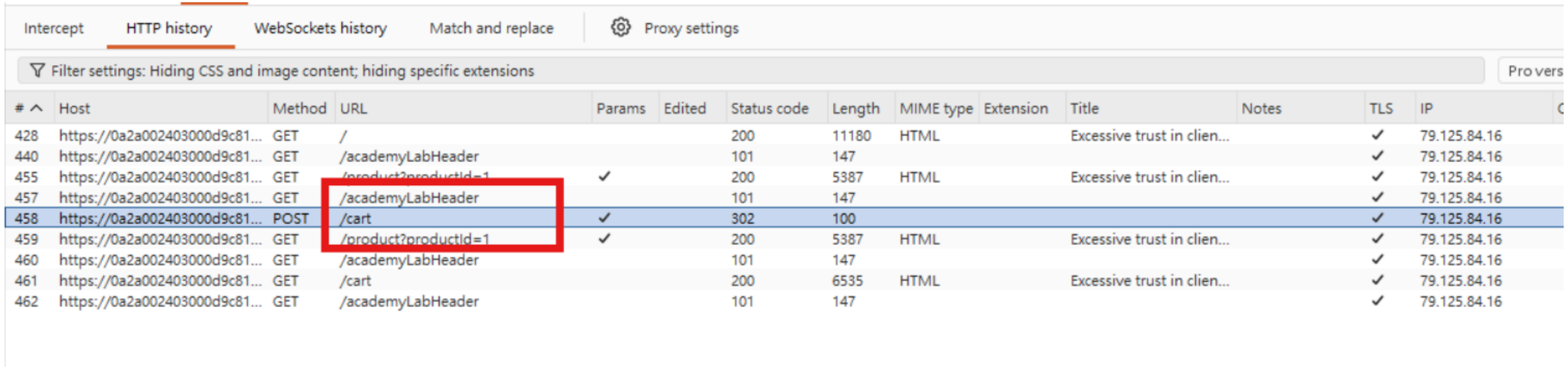
< Return to list



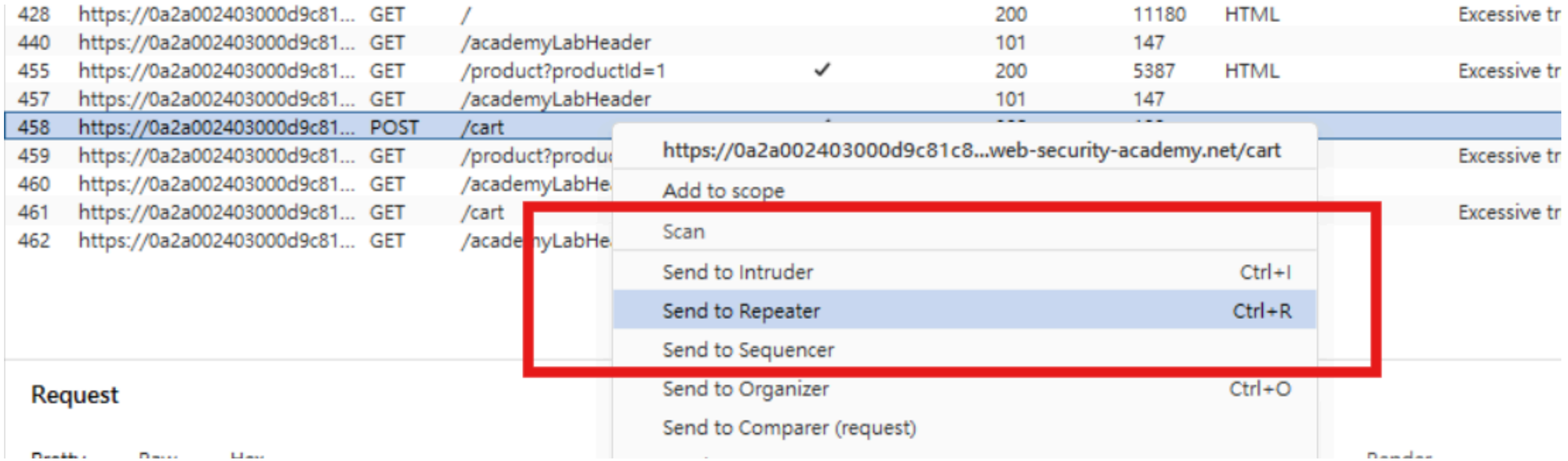
打開 HTTP Proxy


Excessive trust in client-side c
https://0a2a002403000d9c81c8f79000c2007c.web-security-academy.net/product?productId=1
Description:
Do you often feel as though people aren't aware of just how "l33t" you are? Do you find yourself struggling to make others feel inferior with public displays of your advanced "l33t-ness"? If either of these things are at the top of your priority list, it's time to the welcome Lightweight "l33t" Leather Jacket into your life.
Handcrafted from leather and single strands of recycled bitcoin, so you can enjoy environmental smugness on top of your high-ranking leather-clad "l33t" levels, this jacket is far superior to anything currently available on the high street. Once you've explained to your friends and colleagues what "l33t" means, we guarantee you'll be at least 18% cooler when donning your "l33t" leather. Inspired by the term-coiners, the jacket comes with hand-stitched CISSP insignia so you can channel the original elite every time you rock your Lightweight "l33t" Leather Jacket.
Make your apparel as formidable as your intellect, and dazzle noobs the world over, with the Lightweight "l33t" Leather Jacket.*
*Every purchase comes with a free leaflet, detailing how best to explain the superiority of being "l33t" to noobs.
1
Add to cart
< Return to list

按加入購物車


Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro vers
Host Method URL Params Edited Status code Length MIME type Extension Title Notes TLS IP
428 https://0a2a002403000d9c81... GET / 200 11180 HTML Excessive trust in clien... ✓ 79.125.84.16
440 https://0a2a002403000d9c81... GET /academyLabHeader 101 147 ✓ 79.125.84.16
455 https://0a2a002403000d9c81... GET /product?productId=1 ✓ 200 5387 HTML Excessive trust in clien... ✓ 79.125.84.16
457 https://0a2a002403000d9c81... GET /academyLabHeader 101 147 ✓ 79.125.84.16
458 https://0a2a002403000d9c81... POST /cart ✓ 302 100 ✓ 79.125.84.16
459 https://0a2a002403000d9c81... GET /product?productId=1 ✓ 200 5387 HTML Excessive trust in clien... ✓ 79.125.84.16
460 https://0a2a002403000d9c81... GET /academyLabHeader 101 147 ✓ 79.125.84.16
461 https://0a2a002403000d9c81... GET /cart 200 6535 HTML Excessive trust in clien... ✓ 79.125.84.16
462 https://0a2a002403000d9c81... GET /academyLabHeader 101 147 ✓ 79.125.84.16

找到有 /cart 的封包

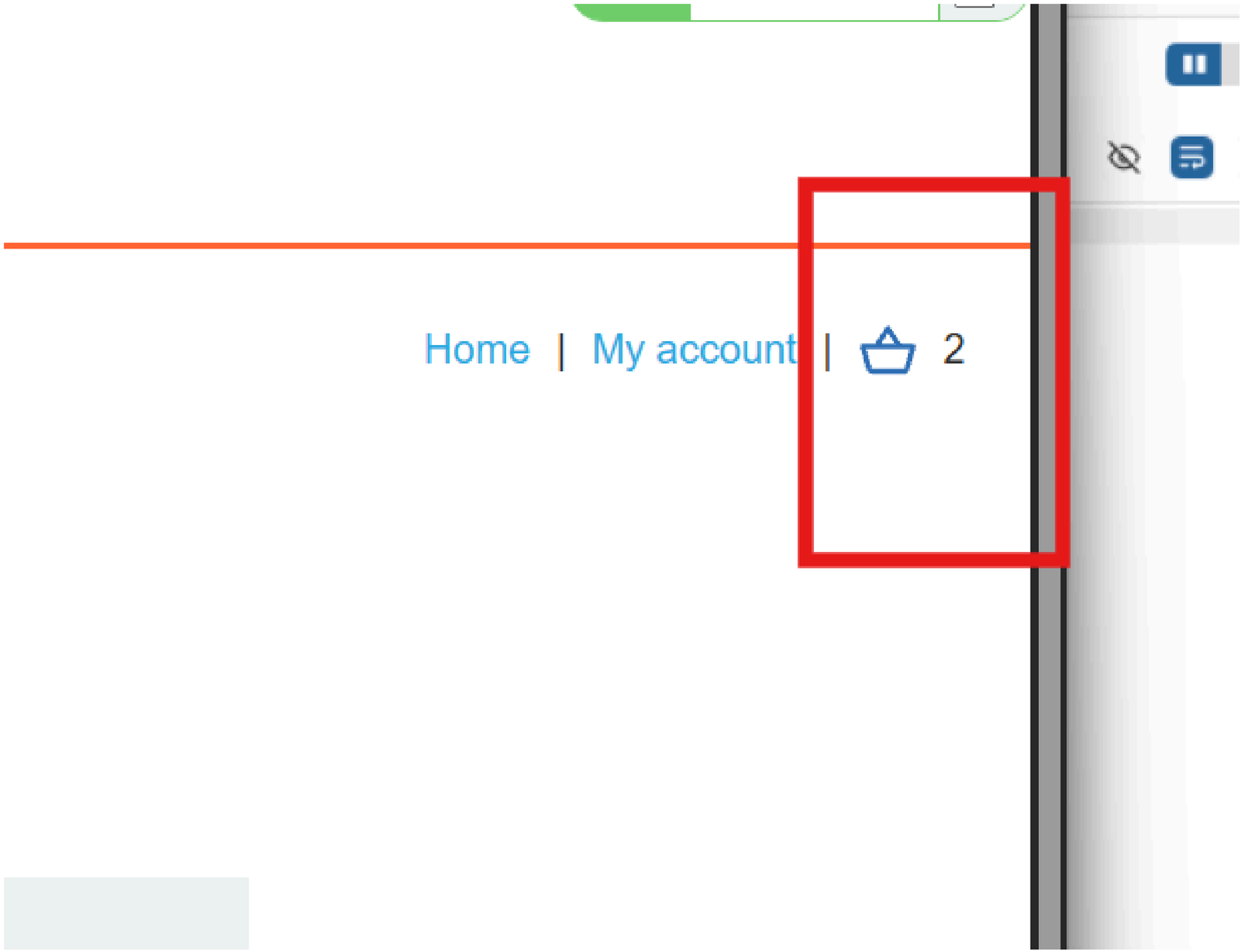


對著他按右鍵

Send to Repeater

```
18 Sec-Fetch-Dest: document
19 Referer:
   https://0a2a002403000d9c81c8f79000c2007c.web-security-academy
   ctId=1
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 productId=1&redir=PRODUCT&quantity=1&price=133700
```

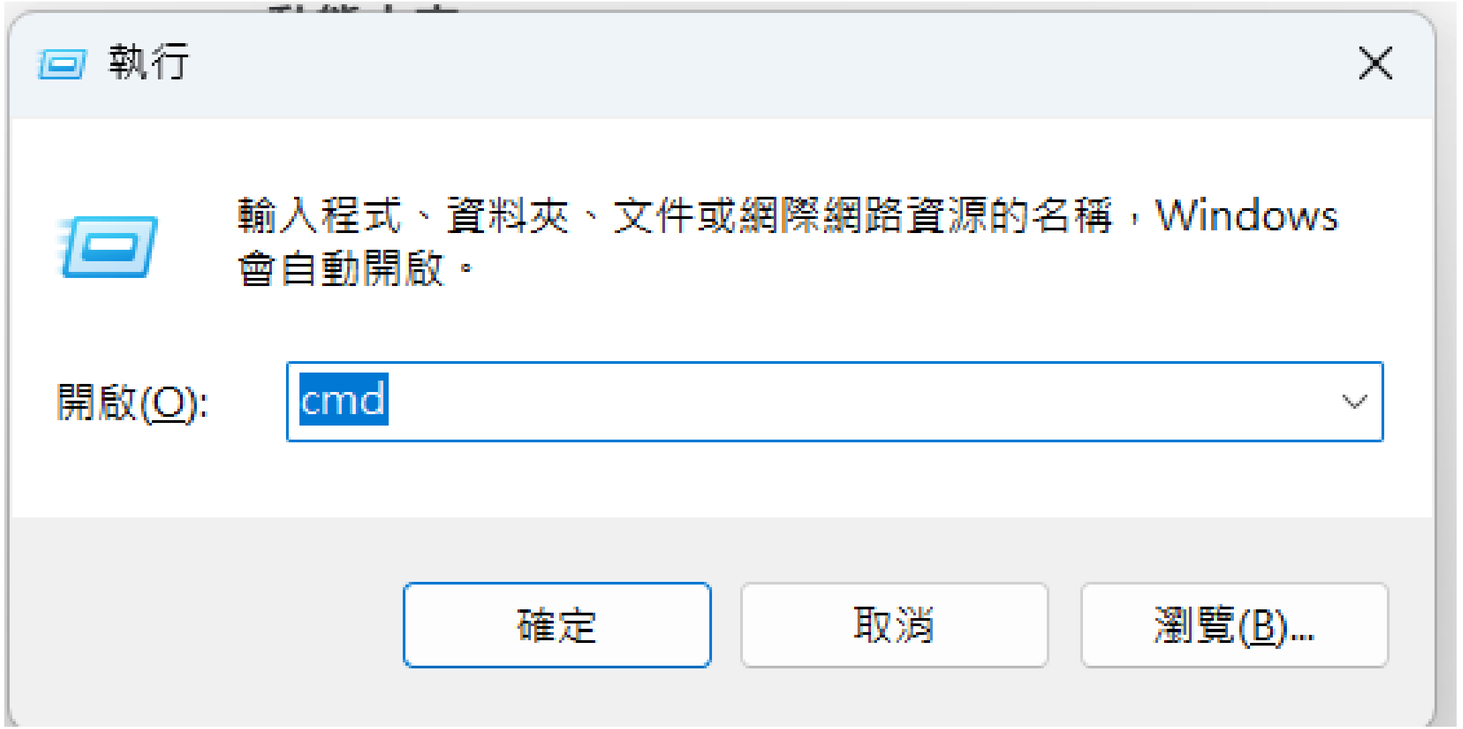
把 price 改成 1 然後送出



回去看購物車


後端
瀏覽器

cURL 怎麼用



Windows+R
打 cmd

curl https://example.com

```
curl -X POST https://example.com
curl -X DELETE https://example.com
```

curl -v https://url.frk.tw/fd-115-1

XST

curl -i -X TRACE "http://xxx.com" -H "XST: <script>alert(1)</script>"



https://app.sli.do/event/3drvaxKxp2vrVheGL1fe2y